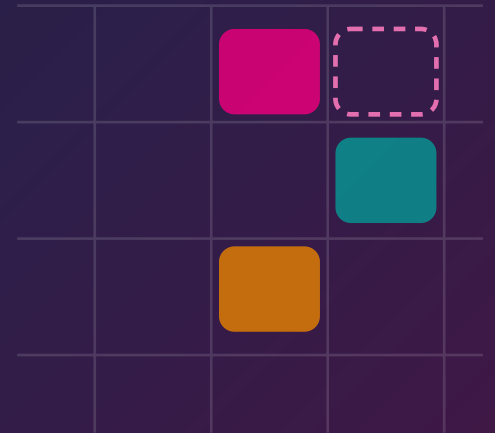


Techniques défensives et offensives des applications Web · Module 2

Le pilotage et la maîtrise des risques

Acteurs, lois, normes et méthodes : le cadre qui transforme la sécurité en démarche **structurée, prouvable et pilotée**.



Objectifs pédagogiques

À la fin de ce module, vous saurez :

- Situer les **acteurs** de la cybersécurité et savoir qui fait quoi.
- Connaître le **cadre juridique** : loi Godfrain, RGPD, NIS 2.
- Distinguer les grands **référentiels et normes** (ISO 27001, PCI-DSS, HDS, IEC 62443).
- Lire les **standards de vulnérabilités** : CVE, CWE, CVSS, EPSS, KEV, IOC, TTP.
- Appliquer une méthode de **threat modeling** (STRIDE) et situer MITRE ATT&CK.
- Relier tout cela aux **enjeux des applications Web**.

Pourquoi « piloter » ?

La sécurité ne se décrète pas, elle se **gouverne** : identifier les risques, s'appuyer sur des **référentiels reconnus**, respecter la **loi**, mesurer avec des **standards communs**. C'est ce qui rend la démarche défendable et reproductible.

À retenir

Un langage et des cadres **partagés** permettent à des équipes différentes — dev, ops, juridique, direction — de parler des **mêmes** risques.

■ Acteurs et cadres ■ Ce que ça change pour un dev ■ Méthode

Six piliers pour maîtriser le risque

1

Les organismes et acteurs

SGDSN, ANSSI, CERT -FR, ENISA, OWASP, MITRE, FIRST, NIST — qui fait quoi

2

Le cadre juridique

Loi Godfrain (art. 323-1 et s.), RGPD, directive NIS 2 et loi résilience

3

Les référentiels et normes

ISO 2700x, IEC 62443, HDS, PCI-DSS ; le référentiel OWASP ASVS et SAMM

4

La gestion des vulnérabilités

CWE, CVE, CVSS, EPSS, KEV, NVD, IOC, TTP — nommer, coter, prioriser

5

Threat modeling et MITRE ATT&CK

STRIDE, démarche en 4 questions, DFD, un exemple complet

6

Les enjeux de la sécurité des applications Web

Synthèse orientée développement : défense en profondeur et « shift left »

01

Les organismes et acteurs de la cybersécurité

Un écosystème d'acteurs publics et communautaires, chacun avec un rôle précis.

Dans cette partie

- La chaîne étatique française
- L'ANSSI en détail
- SGDSN, CERT-FR, ENISA
- OWASP et MITRE côté communauté
- Qui produit quoi : la synthèse

Un écosystème structuré



Deux logiques

Les acteurs **étatiques** protègent la Nation et fixent des règles ; les acteurs **communautaires** produisent des standards ouverts. Les deux se complètent et coopèrent.

L'ANSSI

Définition

L'**ANSSI** (Agence nationale de la sécurité des systèmes d'information, créée en 2009) est l'autorité nationale française en matière de cyberdéfense, rattachée au SGDSN.

Ses missions principales :

- **Protéger** les SI de l'État et des opérateurs critiques — **OIV** et **OSE**, bientôt les **entités essentielles et importantes** de NIS 2.
- **Publier** des guides et règles de l'art directement applicables.
- **Qualifier** des prestataires (**PASSI** pour l'audit) et **certifier** des produits (**CSPN**, Critères Communs).
- **Répondre** aux incidents majeurs, via le CERT-FR.

Concrètement pour un dev

Les **guides ANSSI** — développement sécurisé, durcissement, journalisation, recommandations TLS — sont des références gratuites et applicables immédiatement.

Repères 2026

Le **Référentiel Cyber France (ReCyF)**, publié en mars 2026, traduit NIS 2 en 20 objectifs de sécurité concrets. La plateforme **MonEspaceNIS2** permet de tester son éligibilité.

PASSI

Un prestataire de test d'intrusion **qualifié PASSI** apporte une garantie de méthode — souvent exigée pour les audits d'entités sensibles.

SGDSN, CERT / CSIRT et ENISA



SGDSN

Le **Secrétariat général de la défense et de la sécurité nationale**, rattaché au Premier ministre, assure la **tutelle de l'ANSSI** et coordonne la stratégie nationale, dont le volet cyber.



CERT / CSIRT

Une équipe qui **détecte, analyse et répond** aux incidents. En France : **CERT-FR**, opéré par l'ANSSI, plus des CERT sectoriels et régionaux. À l'international : le réseau **FIRST**.



ENISA

L'**agence de l'Union européenne pour la cybersécurité** : elle produit des lignes directrices, pilote le schéma de **certification européen** et coordonne la réponse à l'échelle de l'UE.

Exemple de rôle du CERT-FR

Publier des **alertes et bulletins** sur les vulnérabilités critiques (ex. Log4Shell), diffuser des **indicateurs de compromission** et coordonner la réponse nationale.

OWASP et MITRE

OWASP

L'**Open Worldwide Application Security Project** est une fondation à but non lucratif qui produit des **ressources ouvertes** de référence pour la sécurité applicative.

Top 10

ASVS

Cheat Sheets

Testing Guide (WSTG)

ZAP

Juice Shop

Dependency-Check

SAMM

Le cœur de cette formation

Top 10 : les 10 risques Web majeurs. **ASVS** : exigences vérifiables sur 3 niveaux. **ZAP / Juice Shop** : outil et application volontairement vulnérable pour s'entraîner.

MITRE

Organisation à but non lucratif financée par l'État américain, elle **maintient les standards** qui structurent la gestion des vulnérabilités et la connaissance des attaques.

- **CVE** — le catalogue des failles identifiées.
- **CWE** — la typologie des faiblesses (et son Top 25).
- **ATT&CK** — la base des tactiques et techniques réelles.

À ne pas confondre

OWASP = côté défense applicative (quoi corriger). **MITRE** = côté connaissance des failles et des attaques (comment on les nomme et on les observe).

Qui fait quoi ?

Acteur	Nature	Rôle principal
SGDSN	État — Premier ministre	Stratégie de sécurité nationale, tutelle de l'ANSSI
ANSSI	État — agence	Autorité cyber : protection, guides, qualification, certification
CERT-FR	État — opéré par l'ANSSI	Détection, alerte et réponse à incident
ENISA	Union européenne	Lignes directrices, certification européenne, coordination UE
OWASP	Communautaire, à but non lucratif	Standards et outils ouverts pour la sécurité applicative
MITRE	À but non lucratif (US)	CVE, CWE, ATT&CK — le vocabulaire des failles et des attaques
NIST	Standardisation (US)	Standards de sécurité ; opère la NVD
FIRST	International	Coordination des CERT/CSIRT ; maintient le standard CVSS

02

Le cadre juridique et les exigences légales

Attaquer un système est un délit ; protéger les données est une obligation.

Dans cette partie

- Pourquoi le droit encadre la cyber
- La loi Godfrain, article par article
- Le RGPD et la CNIL
- Sanctions CNIL récentes
- La directive NIS 2
- Le droit se code aussi

Pourquoi le droit encadre la cybersécurité

Trois logiques complémentaires encadrent la sécurité :

- **Réprimer** les atteintes aux systèmes → **loi Godfrain** (1988), art. 323-1 et s. du Code pénal.
- **Protéger** les données personnelles → **RGPD** (applicable depuis le 25 mai 2018).
- **Imposer un socle** de sécurité aux acteurs critiques → directive **NIS 2**.

Notion clé — STAD

Le droit protège le **Système de Traitement Automatisé de Données** : tout accès ou maintien non autorisé y est réprimé, **même sans dommage ni vol**.

Avertissement pédagogique

Tout ce qu'on apprend en offensive ne se pratique que sur des systèmes **dont on a l'autorisation écrite** (mandat, périmètre). Sinon, c'est pénalement répréhensible.

Exemple

Un simple **scan de ports** ou un accès « juste pour voir » sur le système d'autrui peut déjà constituer un accès frauduleux.

Nuance récente

La loi de 2024 sur la « sécurité intérieure » a créé une **protection du lanceur d'alerte** en sécurité (signalement de bonne foi d'une faille), mais le cadre reste strict.

Les infractions du Code pénal (art. 323-1 et s.)

Article	Infraction	Peine (ordre de grandeur)
323-1	Accès ou maintien frauduleux dans un STAD	3 ans / 100 000 € — aggravé si données altérées
323-2	Entraver ou fausser le fonctionnement d'un STAD	5 ans / 150 000 €
323-3	Introduire, modifier ou supprimer frauduleusement des données	5 ans / 150 000 €
323-3-1	Détenir ou diffuser un moyen conçu pour ces infractions	Peines des infractions visées
323-4-1	Commission en bande organisée	Jusqu'à 10 ans / 300 000 €

Le cœur du délit

L'**intention frauduleuse** et l'**absence d'autorisation**. Le simple **maintien** dans un système où l'on est entré par erreur, une fois l'anomalie constatée, peut suffire à caractériser l'infraction.

Ce que recouvrent ces infractions

Accès frauduleux

Se connecter à un espace d'administration avec des identifiants trouvés ou devinés, sans autorisation.

Maintien frauduleux

Rester dans un système après avoir constaté qu'on n'aurait pas dû y accéder.

Entrave

Lancer un déni de service qui rend un service indisponible pour ses utilisateurs légitimes.

Altération de données

Modifier ou supprimer des enregistrements : défiguration, sabotage d'une base.

Fourniture de moyens

Diffuser un outil ou un exploit spécifiquement conçu pour commettre ces atteintes.

Bande organisée

Agir en groupe structuré aggrave fortement les peines encourues.

Le RGPD et la CNIL

Définition

Le **RGPD** (Règlement général sur la protection des données) encadre le traitement des **données à caractère personnel** des résidents de l'UE. En France, l'autorité de contrôle est la **CNIL**.

- Principes : **licéité, finalité, minimisation, exactitude, conservation limitée, sécurité** (art. 5).
- **Droits** des personnes : accès, rectification, effacement, portabilité, opposition.
- **Sécurité** des traitements : mesures techniques et organisationnelles appropriées (art. 32).
- **Notification** d'une violation à la CNIL sous **72 h**, et information des personnes si risque élevé.

Sanctions dissuasives

Jusqu'à **20 M€** ou **4 % du chiffre d'affaires mondial** annuel — le montant le plus élevé des deux étant retenu.

Ce qui est sanctionné

La CNIL ne punit pas l'existence de la faille — nul n'est à l'abri — mais l'**insuffisance des mesures** de prévention, de détection et de gestion de l'incident (art. 32).

Le RGPD sanctionne les failles de sécurité

Free / Free Mobile

42 M€

Janvier 2026. Fuite d'octobre 2024 : 24 millions de contrats, dont des IBAN. VPN faiblement protégé, un formulaire interne renvoyait l'IBAN complet.

France Travail

5 M€

Janvier 2026. Données d'un grand nombre de demandeurs d'emploi exposées via des comptes de conseillers partenaires détournés.

Sanctions 2025

cookies ·
sécurité

Les thèmes récurrents des sanctions CNIL : cookies, surveillance des salariés et sécurité des données.

La leçon commune

Dans le dossier Free, la CNIL a relevé une **authentification VPN insuffisante** et une **conservation excessive** de données. Trois mesures — MFA, moindre privilège, purge — auraient réduit la sanction. Ce sont exactement les sujets des modules techniques à venir.

Sources : décisions CNIL des 13 et 22 janvier 2026 (délibérations publiées).

La directive NIS 2

Définition

La directive **NIS 2** (UE 2022/2555) élargit fortement les obligations de cybersécurité. En France, elle est transposée par la **loi relative à la résilience des infrastructures critiques** (dite loi résilience).

- Deux catégories : **entités essentielles (EE)** et **entités importantes (EI)**, selon secteur et taille.
- Périmètre passant d'environ **500 à ~15 000 entités** en France.
- Obligations : gestion des risques, **enregistrement** auprès de l'ANSSI, **notification** d'incident (alerte à 24 h, notification à 72 h, rapport à 1 mois).
- **Responsabilité des dirigeants** engagée.

Sanctions

Jusqu'à **10 M€ ou 2 % du CA mondial** (entités essentielles), **7 M€ ou 1,4 %** (entités importantes).

L'effet ricochet

Même non concernée directement, une PME peut se voir imposer des exigences NIS 2 par ses **grands donneurs d'ordre**, tenus de sécuriser leur chaîne d'approvisionnement.

État en 2026

Loi en cours d'adoption (promulgation attendue) ; le **ReCyF** de l'ANSSI en donne déjà le contenu concret. À vérifier au moment de la formation.

Le droit se code aussi



Privacy by design

La protection des données dès la conception et par défaut



Minimisation

Ne collecter que le strict nécessaire à la finalité



Sécurité (art. 32)

Chiffrement, contrôle d'accès, MFA, journalisation



Conservation limitée

Durées définies, purge automatique des données



Traçabilité

Registre des traitements, journaux, preuves de conformité



Consentement

Recueilli, clair, aussi simple à retirer qu'à donner

Le lien avec la suite

La plupart des exigences RGPD se traduisent en **mesures techniques** concrètes — chiffrement, contrôle d'accès, journalisation — que l'on retrouvera dans les modules OWASP. Le juridique et le code se rejoignent.

03

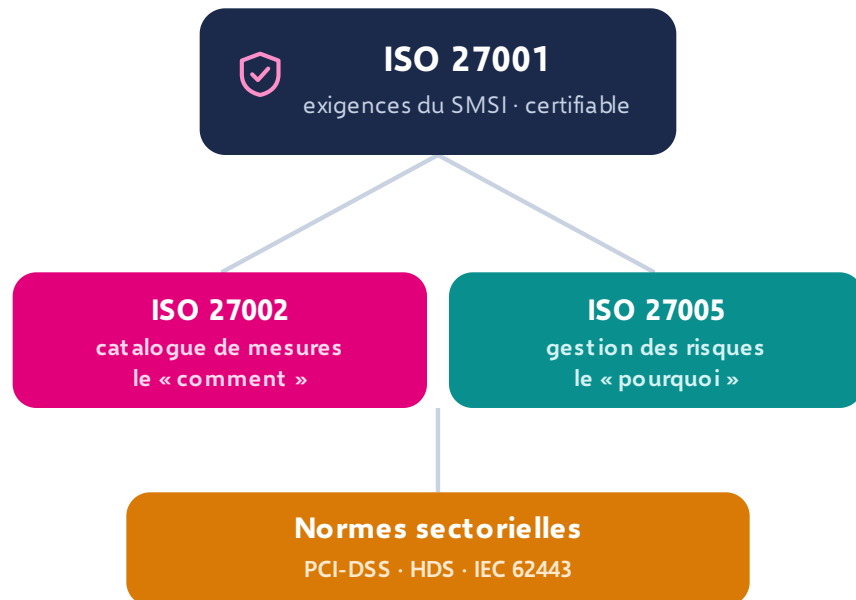
Les référentiels et les normes

Des cadres reconnus pour organiser, prouver et faire certifier sa sécurité.

Dans cette partie

- Normes génériques et sectorielles
- La famille ISO 2700x et le SMSI
- PCI-DSS, HDS, IEC 62443
- Le cycle PDCA
- Côté applicatif : OWASP ASVS et SAMM
- Quelle norme pour quel besoin

La famille ISO 2700x et les normes sectorielles



Les normes se répartissent en deux grands types :

- **Génériques** : la famille **ISO/IEC 2700x**, applicable à toute organisation.
- **Sectorielles** : adaptées à un domaine — **PCI-DSS** (paiement), **HDS** (santé), **IEC 62443** (industrie).

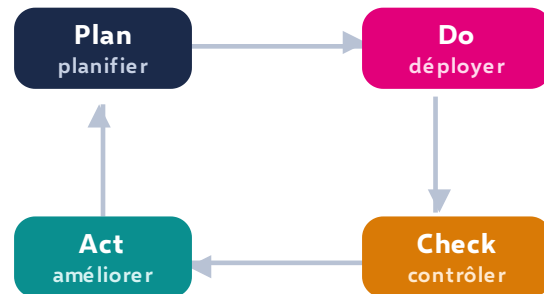
Certification ou guide ?

ISO 27001, PCI-DSS et HDS donnent lieu à une **certification** (audit d'un organisme accrédité). ISO 27002 et 27005 sont des **guides et méthodes** : on ne s'y « certifie » pas.

Le SMSI et sa boucle d'amélioration

Définition — SMSI

Un **Système de Management de la Sécurité de l'Information** (*ISMS*) est l'organisation d'ensemble — politiques, rôles, processus et mesures — qu'une entité met en place pour **gérer durablement** la sécurité. Il tourne en boucle d'amélioration continue **PDCA**.



ISO 27001

Les **exigences** du SMSI. Le « quoi » : ce qu'il faut mettre en place. Certifiable.

ISO 27002

Le **catalogue de mesures** à choisir selon les risques. Le « comment ».

ISO 27005

La **gestion des risques**. Le « pourquoi » : justifie le choix des mesures.

En France

La méthode **EBIOS Risk Manager** de l'ANSSI est l'équivalent opérationnel d'ISO 27005 pour analyser les risques.

Paieement et santé



PCI-DSS

Payment Card Industry Data Security Standard : exigences pour toute entité qui **traite, stocke ou transmet** des données de cartes bancaires.

Exemples d'exigences

Ne jamais stocker le cryptogramme, chiffrer les données de carte, segmenter le réseau, journaliser les accès, tester régulièrement.



HDS

La certification **Hébergeur de Données de Santé** (France) est **obligatoire** pour héberger des données de santé à caractère personnel.

Fondement

S'appuie sur ISO 27001, avec des exigences complémentaires propres à la santé (traçabilité, réversibilité, localisation).

Contraintes de marché

Ces normes sont souvent **contractuellement imposées** : sans conformité, pas d'accès au marché — encaissement par carte, hébergement de données de santé.

IEC 62443 — les systèmes industriels

Définition

La norme **IEC 62443** couvre la sécurité des **IACS** (systèmes industriels d'automatisation et de contrôle), c'est-à-dire l'**OT** (technologie opérationnelle des usines), par opposition à l'IT de gestion. Elle vise automates, réseaux **SCADA**, énergie, transport.

Un monde différent de l'informatique de gestion :

- Priorité à la **disponibilité** et à la **sûreté** (safety) avant la confidentialité — l'inverse de l'IT.
- Équipements à **très longue durée de vie**, difficiles à corriger.
- Approche par **zones et conduits** (cloisonnement).

Exemple d'enjeu

Sur une ligne de production, un correctif ne peut pas toujours être appliqué immédiatement : arrêter la machine coûte cher et peut être dangereux. La sécurité passe alors par la **segmentation** et la **surveillance**.

Pourquoi ça vous concerne

De plus en plus d'usines exposent des interfaces **Web** de supervision. Le développeur Web y retrouve les mêmes failles — mais avec un impact physique.

Les référentiels OWASP : ASVS et SAMM



ASVS — vérifier

Application Security Verification Standard : un référentiel d'**exigences vérifiables** pour une application, organisé en trois niveaux de rigueur.

- **Niveau 1** — vérifiable par tests en boîte noire ; socle minimal.
- **Niveau 2** — la plupart des applications qui traitent des données sensibles.
- **Niveau 3** — applications critiques (santé, finance, vies humaines).

S'utilise comme grille d'audit et comme cahier des charges de sécurité.



SAMM — mesurer et progresser

Software Assurance Maturity Model : un modèle pour **évaluer et faire progresser** la maturité sécurité d'une organisation sur l'ensemble du cycle de développement.

Cinq fonctions : gouvernance, conception, implémentation, vérification, opérations — chacune notée sur des niveaux de maturité.

Le duo

ASVS mesure une **application** ; **SAMM** mesure une **organisation**.

Quelle norme pour quel besoin ?

Norme	Périmètre	Nature
ISO 27001	Management de la sécurité (toute organisation)	Certifiable
ISO 27002	Catalogue de mesures de sécurité	Guide
ISO 27005 / EBIOS RM	Gestion des risques	Méthode
PCI-DSS	Données de cartes de paiement	Certifiable (imposée par le marché)
HDS	Hébergement de données de santé (France)	Certifiable (obligatoire)
IEC 62443	Systèmes industriels / OT	Certifiable (par niveaux)
OWASP ASVS	Exigences de sécurité d'une application	Référentiel de vérification
OWASP SAMM	Maturité sécurité d'une organisation	Modèle de maturité

04

Les standards de gestion des vulnérabilités

Un langage commun pour nommer, classer, coter et prioriser les faiblesses.

Dans cette partie

- Comment les standards s'articulent
- CVE et NVD
- CWE et son Top 25
- CVSS : la gravité
- EPSS et KEV : la priorité
- IOC, TTP et la pyramide de la douleur

Comment ces standards s'articulent



À lire ainsi

Une **CVE** est une **instance** d'un type décrit par une **CWE** ; on lui attribue un score **CVSS** ; **EPSS** et **KEV** disent s'il faut la traiter en priorité ; la **NVD** publie l'ensemble.

Pourquoi c'est vital

Un même incident peut alors être décrit à l'identique par un chercheur au Japon, un éditeur aux États-Unis et un RSSI en France. **Le vocabulaire commun rend la défense coordonnée possible.**

CVE et NVD

CVE

Common Vulnerabilities and Exposures (géré par MITRE) : un **identifiant unique** par vulnérabilité publiquement connue.

Format : **CVE-AAAA-NNNNN** — l'année, puis un numéro de séquence.

NVD

National Vulnerability Database (opérée par le **NIST**) : la base qui **enrichit** chaque CVE — score CVSS, CWE associée, produits et versions affectés.

La source de référence pour la veille. En Europe, l'ENISA opère l'**EUVD**, une base équivalente.

Exemple concret

CVE-2021-44228 — « **Log4Shell** » — faille critique de Log4j, notée **CVSS 10.0**. Un identifiant unique a permis au monde entier de parler **de la même faille** et de la suivre en temps réel.

CWE et son Top 25

Définition

La **CWE** (Common Weakness Enumeration) est un **dictionnaire des types de faiblesses**. Là où la CVE nomme **une faille précise**, la CWE nomme **la catégorie** de défaut.

Le **CWE Top 25** (MITRE/CISA) classe chaque année les faiblesses les plus dangereuses, d'après les CVE réelles. En 2025, le trio de tête est **entièrement Web**.

1	CWE-79	Cross-Site Scripting (XSS)	Web
2	CWE-89	Injection SQL	Web
3	CWE-352	Cross-Site Request Forgery (CSRF)	Web
4	CWE-862	Autorisation manquante	Web
5	CWE-787	Écriture hors limites (mémoire)	sys
6	CWE-22	Traversée de répertoire (path traversal)	Web

Extrait du CWE Top 25 · 2025 (MITRE/CISA), sur 39 080 CVE analysées.

Ce que ça dit

Cinq des six faiblesses les plus dangereuses touchent directement le **développement Web**. C'est exactement le périmètre des modules suivants.

CVSS — un score de 0 à 10

0.1 – 3.9
Faible

4.0 – 6.9
Moyen

7.0 – 8.9
Élevé

9 – 10
Critique

Définition

Le **CVSS** (Common Vulnerability Scoring System, maintenu par le FIRST) exprime la gravité d'une faille par un **score de 0 à 10** et un **vecteur** détaillant les critères : vecteur d'attaque, complexité, privilèges requis, interaction, impact D-I-C.

Attention — le piège du CVSS

Il mesure la **gravité intrinsèque**, pas le **risque réel** chez vous. Une faille « critique » sur un composant non exposé peut être **moins urgente** qu'une « moyenne » en frontal sur Internet.

Version actuelle : CVSS v4.0, publiée par le FIRST.

EPSS et KEV : du score à la décision

EPSS — la probabilité

Exploit Prediction Scoring System (FIRST) : une **probabilité de 0 à 100 %** qu'une faille soit exploitée dans les **30 prochains jours**, calculée sur des données réelles.

Usage

Répond à « **va-t-elle** être attaquée ? » — là où le CVSS ne dit que « à quel point ce serait grave ? ».

KEV — la réalité

Le catalogue **Known Exploited Vulnerabilities** (CISA) liste les failles **déjà exploitées** dans la nature, preuves à l'appui.

Usage

Une CVE au KEV = **à corriger en urgence**, quel que soit son score CVSS. C'est un fait, pas une estimation.

La bonne méthode de priorisation

Croiser les trois : **CVSS** (gravité) × **EPSS** (probabilité) × **exposition réelle** chez soi, et traiter d'abord tout ce qui figure au **KEV**. Le DBIR 2026 le rappelle : seule une minorité des failles critiques est corrigée à temps — mieux vaut prioriser juste que patcher tout.

IOC — indicateurs de compromission

Définition

Un **IOC** (Indicator of Compromise) est une **trace observable** qui signale qu'un système a peut-être été compromis.

Ils alimentent les outils de détection et se partagent entre équipes et CERT :

- Le **SIEM** (Security Information and Event Management) centralise et corrèle les journaux.
- L'**EDR** (Endpoint Detection and Response) surveille postes et serveurs.
- Format d'échange standardisé : **STIX / TAXII**, entre CERT.

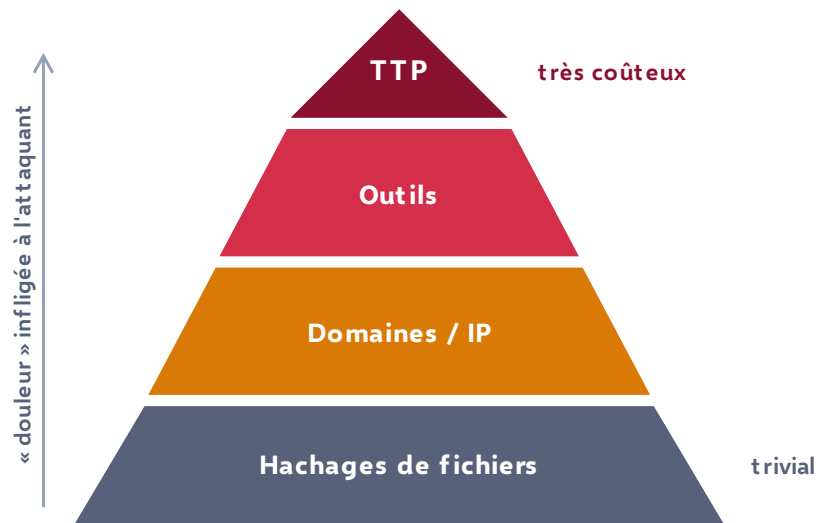
Exemples d'IOC

- Une **empreinte (hash)** de fichier malveillant
- Une **adresse IP** ou un **domaine** de serveur de commande (C2)
- Une clé de registre ou un nom de fichier suspect
- Un motif de trafic réseau anormal

Limite

Un IOC décrit ce qui **s'est déjà passé**. Un attaquant change facilement de hash ou d'IP — d'où l'intérêt de monter d'un cran, vers les TTP.

TTP et la « pyramide de la douleur »



Définition

Les **TTP** (Tactics, Techniques and Procedures) décrivent le **comportement** de l'attaquant : ses objectifs (tactiques), ses méthodes (techniques) et sa manière de faire (procédures).

La **pyramide de la douleur** (David Bianco) montre l'effet de chaque type d'indicateur qu'on bloque :

- Bloquer un **hash** ou une **IP** gêne peu : l'attaquant en change en une minute.
- Contrer ses **TTP** le force à **revoir toute sa méthode** — bien plus efficace et durable.

Le lien

C'est précisément ce que catalogue **MITRE ATT&CK**, vu à la partie suivante.

05

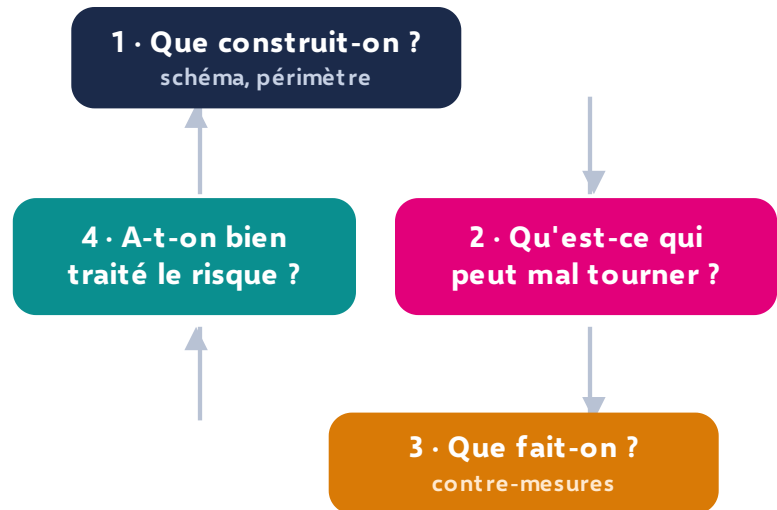
Le threat modeling et MITRE ATT&CK

Anticiper les menaces dès la conception, et s'appuyer sur les techniques réellement observées.

Dans cette partie

- Le principe du threat modeling
- La méthode STRIDE
- La démarche en pratique
- Un exemple complet
- MITRE ATT&CK
- STRIDE, Kill Chain, ATT&CK : lequel quand

Qu'est-ce que le threat modeling ?



Définition

Le **threat modeling** (modélisation des menaces) est une démarche **structurée** pour identifier, dès la conception, ce qui pourrait mal tourner et comment s'en prémunir.

Popularisée par les **quatre questions** d'Adam Shostack, elle se pratique en atelier, autour d'un schéma de l'application. C'est du « **shift left** » : réfléchir aux menaces **avant** d'écrire le code, là où les corrections coûtent le moins cher.

À retenir

Corriger une faille en conception coûte une fraction de ce qu'elle coûte en production. Le threat modeling est l'outil le plus rentable de la sécurité applicative.

Six catégories de menaces

Lettre	Menace	Propriété visée	Exemple sur une application Web
S	Spoofing (usurpation)	Authentification	Se faire passer pour un autre utilisateur
T	Tampering (altération)	Intégrité	Modifier un paramètre ou une donnée en base
R	Repudiation (répudiation)	Preuve, non-répudiation	Nier une action faute de journalisation
I	Information disclosure (divulgation)	Confidentialité	Fuite de données via une erreur ou une injection
D	Denial of service	Disponibilité	Rendre le service indisponible
E	Elevation of privilege (élévation)	Autorisation	Passer d'utilisateur à administrateur

Le lien avec le module 1

Chaque menace STRIDE casse un critère **D-I-C-P** : STRIDE est la version « côté conception » du triptyque vu au module précédent.

Modéliser en pratique

1

Cartographier l'application

Schéma de flux de données (DFD) : composants, échanges, dépôts, et frontières de confiance

2

Identifier les menaces

Passer chaque élément et chaque flux au crible des six lettres de STRIDE

3

Coter et prioriser

Estimer vraisemblance × impact ; se concentrer sur les risques majeurs (matrice du module 1)

4

Définir et vérifier les contre-mesures

Réduire, transférer, éviter ou accepter — puis contrôler que le risque est bien traité

Frontière de confiance

C'est la ligne que franchit une donnée en changeant de niveau de confiance — navigateur → serveur, application → base. **Les menaces se concentrent sur ces frontières** : c'est là qu'il faut valider et contrôler.

STRIDE sur un formulaire de connexion

	Menace concrète	Contre-mesure	Exigence ASVS / OWASP
S	Vol d'identifiants, bourrage d'identifiants	MFA, détection des connexions anormales	Broken Access Control
T	Modification du jeton de session côté client	Jeton signé, cookie HttpOnly + Secure	Cryptographic Failures
R	L'utilisateur nie une action sensible	Journalisation horodatée et intègre	Logging & Alerting Failures
I	Message d'erreur révélant si le compte existe	Messages d'erreur génériques	Security Misconfiguration
D	Force brute saturant le service d'auth	Limitation du débit, verrouillage temporisé, CAPTCHA	Insecure Design
E	Un paramètre role=admin forcé	Autorisation vérifiée côté serveur, à chaque requête	Broken Access Control

Ce que montre l'exercice

Un seul écran génère **six familles de menaces** et autant de parades — toutes reliées à un risque de l'**OWASP Top 10**. C'est le pont direct vers les modules techniques.

Le catalogue des techniques réelles

Définition

MITRE ATT&CK est une **base de connaissances** des **tactiques** (le « pourquoi », l'objectif) et des **techniques** (le « comment ») réellement observées chez les attaquants.

Organisée en **matrice** : les colonnes sont des tactiques (accès initial, exécution, persistance, exfiltration...), remplies de **techniques** concrètes et documentées, chacune avec un identifiant **Txxxx**.

Usage côté défense

Cartographier ses détections technique par technique, repérer les **angles morts**, et parler le même langage entre red team et blue team.

Accès initial	Exécution	Persistance	Exfiltration
Hameçonnage	Script malveillant	Tâche planifiée	Canal C2 chiffré
Faible exposée	Commande OS	Compte caché	Vers le cloud
Compte valide	Outil légitime	Webshell	

14 tactiques · des centaines de techniques documentées

Chaque case observée dans un incident
= une technique à détecter et à couvrir

STRIDE, Kill Chain et ATT&CK

Cadre	Question à laquelle il répond	Quand l'utiliser
STRIDE	Quelles catégories de menaces pèsent sur ma conception ?	À la conception (threat modeling)
Cyber Kill Chain	Quelles sont les grandes phases d'une attaque ?	Pour raconter et situer un incident
MITRE ATT&CK	Quelles techniques précises l'attaquant emploie-t-il ?	Pour outiller la détection (blue team)

STRIDE
Aide à **concevoir** sûr, avant le code.

Kill Chain
Donne le **récit** d'une attaque, pour communiquer.

ATT&CK
Fournit le **catalogue opérationnel** pour détecter.

Complémentarité
Ensemble, ils couvrent **conception, narration et détection** : les trois temps de la maîtrise du risque.

06

Les enjeux de la sécurité des applications Web

Pourquoi le Web concentre l'essentiel des risques applicatifs.

Dans cette partie

- Le Web, cible permanente
- Quatre enjeux majeurs
- Défense en profondeur et « shift left »
- La sécurité tout au long du cycle

Le Web, cible permanente et exposée

Une application Web est, par nature, **exposée en continu sur Internet** — donc atteignable par n'importe quel attaquant, à tout moment, depuis n'importe où.

- Accessible **24 h/24**, sans barrière physique.
- Surface riche : formulaires, API, cookies, fichiers, **dépendances tierces**.
- Cible de **scans automatisés** permanents, quelques minutes après la mise en ligne.

Chiffre 2026

D'après le Verizon DBIR 2026, l'**exploitation de vulnérabilités** est devenue le premier vecteur d'accès initial (~31 %), devant les identifiants volés.

C'est là que se concentrent les failles

La majorité des vulnérabilités exploitées touchent la **couche applicative**. Le rappel du CWE Top 25 est net : **5 des 6 faiblesses les plus dangereuses sont des faiblesses Web**.

Le fil rouge

D'où le rôle central de l'**OWASP Top 10**, colonne vertébrale des modules techniques qui suivent.

Quatre enjeux majeurs



Protéger les données

Personnelles, financières, secrets métier



Maintenir la confiance

Des clients, partenaires et utilisateurs



Assurer la conformité

RGPD, NIS 2, PCI-DSS, HDS, ASVS



Sécuriser la chaîne

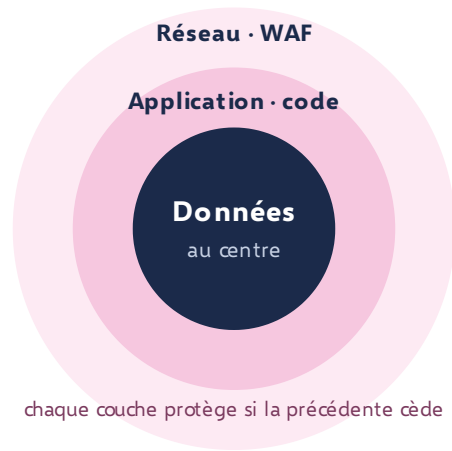
Dépendances, API, fournisseurs

Le lien

Ces quatre enjeux justifient toute la démarche du module : s'appuyer sur des **acteurs**, respecter la **loi**, suivre des **normes**, parler un **langage commun** et **modéliser les menaces**.

La « sécurisation de la chaîne » fait écho au nouveau risque OWASP Top 10:2025 « Software Supply Chain Failures » et au coût moyen record d'une violation : 4,99 M\$ (IBM, 2026).

Défense en profondeur et « shift left »



Défense en profondeur

Empiler **plusieurs couches** de protection indépendantes — réseau, application, données. Si l'une cède, les autres tiennent encore. **Aucune mesure unique n'est suffisante.**

Shift left

Intégrer la sécurité **au plus tôt** dans le cycle de développement, plutôt qu'en fin de projet : threat modeling en conception, analyse dès le commit, tests avant la mise en production.

L'un ne va pas sans l'autre

Le « shift left » réduit le nombre de failles introduites ; la défense en profondeur limite l'impact de celles qui passent malgré tout.

La sécurité tout au long du cycle

Concevoir	Coder	Construire	Tester	Déployer	Exploiter
Threat modeling STRIDE, exigences ASVS dès les specs	Bonnes pratiques Guides ANSSI/OWASP, revue de code	SAST · SCA Analyse du code et des dépendances	DAST · pentest ZAP, tests d'intrusion sur le périmètre	Durcissement Config, secrets, moindre privilège	Détection SIEM/EDR, IOC, veille CVE/KEV

La boucle est bouclée

On retrouve, répartis sur le cycle, **tous les concepts du module** : acteurs (ANSSI, OWASP), normes (ASVS), standards (CVE, KEV), méthodes (STRIDE). La sécurité n'est pas une étape, c'est une **propriété continue**.

Les acronymes du module en un coup d'œil

SI — Système d'Information

SGDSN — Secrétariat Général de la Défense et de la Sécurité Nationale

ENISA — Agence de l'UE pour la cybersécurité

MITRE — organisme US ; CVE, CWE, ATT & CK

EE / EI — Entités Essentielles / Importantes (NIS 2)

RGPD / CNIL — règlement de protection des données / autorité FR

IEC 62443 / OT / SCADA — sécurité industrielle

CVE — Common Vulnerabilities and Exposures (faible)

EPSS — probabilité d'exploitation

TTP — Tactics, Techniques and Procedures

STRIDE — Spoofing, Tampering, Repudiation, Info disclosure, DoS, Elevation

ASVS / SAMM — exigences vérifiables / maturité (OWASP)

SMSI / ISMS — Système de Management de la Sécurité de l'Information

ANSSI — Agence Nationale de la Sécurité des SI

FIRST — Forum of Incident Response and Security Teams

NIST / NVD — standardisation US / base de vulnérabilités

NIS 2 — directive européenne de cybersécurité

PCI-DSS — norme de sécurité des données de carte

PDCA — Plan-Do-Check-Act (amélioration continue)

CWE — Common Weakness Enumeration (type de faiblesse)

KEV — catalogue des failles déjà exploitées (CISA)

SIEM / EDR — corrélation de journaux / détection sur postes

ATT & CK — base MITRE de tactiques et techniques

SAST / DAST / SCA — analyse statique / dynamique / des dépendances

STAD — Système de Traitement Automatisé de Données

CERT / CSIRT — équipe de réponse aux incidents

OWASP — Open Worldwide Application Security Project

OIV / OSE — Opérateurs d'Importance Vitale / de Services Essentiels

PASSI / CSPN — audit qualifié / certification de 1^{er} niveau

HDS — Hébergeur de Données de Santé

EBIOS RM — méthode française d'analyse de risque

CVSS — score de gravité (0–10)

IOC — Indicator of Compromise

STIX / TAXII — formats d'échange de renseignement

DFD — Data Flow Diagram (schéma de flux)

MFA — authentification multifacteur

Ce qu'il faut retenir de ce module

- 1 Un **écosystème d'acteurs** structure la cybersécurité : SGDSN, ANSSI, CERT-FR, ENISA côté État ; OWASP, MITRE côté communauté.
- 2 Le **droit** réprime les atteintes (Godfrain), protège les données (RGPD, CNIL) et impose un socle (NIS 2). Les sanctions sont réelles et lourdes.
- 3 Des **normes** organisent et font certifier la sécurité : ISO 2700x et son SMSI, PCI-DSS, HDS, IEC 62443 ; OWASP ASVS côté application.
- 4 Des **standards communs** (CVE, CWE, CVSS, EPSS, KEV) donnent un langage partagé et permettent de **prioriser**, pas seulement de coter.
- 5 Le **threat modeling** (STRIDE) anticipe en conception ; **ATT&CK** outille la détection. Le Web est la cible n°1 : défense en profondeur et « shift left ».

Et ensuite ?

Nous passons du cadre à la pratique :

DevSecOps et « shift left » outillé

OWASP Top 10:2025, risque par risque

Attaque et défense en TP

Le fil directeur

Tout ce module servait à répondre à une question : **comment rendre la sécurité défendable** — devant un auditeur, un juge, une direction. La réponse tient en quatre mots : acteurs, lois, normes, méthodes.

Sources et références

Cadres et acteurs

- **ANSSI** — guides, ReCyF, MonEspaceNIS2 · cyber.gouv.fr
- **ENISA** — enisa.europa.eu · base EUVD
- **OWASP** — Top 10, ASVS, SAMM · owasp.org
- **MITRE** — CVE, CWE, ATT&CK · attack.mitre.org

Standards de vulnérabilités

- **CWE Top 25 · 2025** (MITRE/CISA) — cwe.mitre.org/top25
- **NVD** (NIST) · **KEV** (CISA) · **EPSS** (FIRST)
- **CVSS v4.0** — first.org/cvss

Chiffres cités

- **Verizon** — DBIR 2026 (exploitation de failles : 1^{er} vecteur)
- **IBM** — Cost of a Data Breach 2026 (4,99 M\$)
- **CNIL** — sanctions Free et France Travail (janvier 2026)

Points à actualiser

La transposition de **NIS 2** (loi résilience) évoluait encore à l'automne 2026 ; les rapports annuels (ANSSI, Verizon, IBM) et les listes CWE/OWASP sont réédités chaque année. Vérifier avant chaque session.

Fin du module 2

Des questions ?

Nous savons désormais **qui** encadre la sécurité, quelles **lois** et **normes** s'appliquent, quel **langage** commun l'outille et comment **modéliser les menaces**. Place à la pratique : DevSecOps et l'OWASP Top 10.